Semana 07 — Repetir el ataque y demostrar que ya no funciona

Grupo 3 · rol Rojo · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	07 de 10
Fase	3 — Defensa y hardening
Grupo	3
Rol	Rojo
Entrega	GitHub, carpeta semana_07/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Ejecuta la técnica ofensiva sobre el objetivo autorizado: prepara el entorno, lanza el ataque, registra comandos y payloads, y guarda cada salida con su hash.

- Confirmar el objetivo autorizado y preparar el entorno antes de la primera captura.
- Ejecutar la técnica de la semana en el orden de los pasos y guardar cada salida cruda con su hash.
- Redactar la reproducción: comando, salida esperada y salida obtenida, sin retocar la evidencia.

2 Qué aporta este rol al entregable

Evidencia cruda en semana_NN/evidencia y el apartado de reproducción del informe.

3 Ejemplo paso a paso

El rol Rojo conserva los payloads de la semana 5 y los repite contra la copia parcheada. La prueba es el mismo ataque, no uno parecido.

3.1 Guardar la evidencia del antes en la copia sin parchear

Se reproduce cada hallazgo y se guardan peticion y respuesta. Esta evidencia es la referencia contra la que se compara el despues.

```
mkdir -p semana_07/evidencia
curl -s -b semana_07/evidencia/cookies.txt \
  'http://127.0.0.1:8081/vulnerabilities/sqli/?id=1%27+OR+%271%27%3D
     %271&Submit=Submit' \
  > semana_07/evidencia/sqli_antes.html
grep -c 'First name' semana_07/evidencia/sqli_antes.html \
  > semana_07/evidencia/sqli_antes_conteo.txt
```

3.2 Reaplicar el mismo payload sobre el codigo parcheado

Se cambia solo el destino: mismo parametro, mismo orden, misma sesion. Si el resultado ya no devuelve filas extra, la mitigacion se sostiene.

```
curl -s -b semana_07/evidencia/cookies.txt \
  'http://127.0.0.1:8081/vulnerabilities/sqli/?id=1%27+OR+%271%27%3D
     %271&Submit=Submit' \
  > semana_07/evidencia/sqli_despues.html
grep -c 'First name' semana_07/evidencia/sqli_despues.html \
  > semana_07/evidencia/sqli_despues_conteo.txt
diff semana_07/evidencia/sqli_antes_conteo.txt \
  semana_07/evidencia/sqli_despues_conteo.txt || true
```

3.3 Probar una variante del mismo ataque

Cambiar mayusculas, comentarios o codificacion es parte del mismo ataque. Si la variante funciona, el parche cubrio el ejemplo y no la causa.

3.4 Documentar la regresion funcional

Ademas de que el ataque falle, la funcionalidad legitima debe seguir funcionando. Se prueban los casos normales del formulario.

3.5 Hallazgo, payload y resultado despues

Hallazgo, payload y resultado despues

Hallazgo	Payload original	Resultado	Variante probada	Conclusion
Inyeccion SQL	Comilla y OR tautologico	Sin filas extra	Mayusculas y comentario	Mitigado
XSS reflejado	Script en name	Texto codificado	Etiqueta img	Mitigado
LFI	Secuencia ../ en page	Error controlado	Codificacion URL	Mitigado
Formulario legitimo	Consulta normal	Funciona igual	No aplica	Sin regresion

La columna de variante se llena solo si se probo; si no, se marca como no probada en lugar de suponer que tambien falla.

4 Qué guardar en el repositorio

Se entrega la evidencia antes y despues con el mismo payload, el resultado de la variante y la comprobacion de que la funcionalidad legitima sigue operativa.

```
semana_07/
|-- informe.md
|-- codigo/
|-- evidencia/
|   |-- sqli_antes.html
|   |-- sqli_despues.html
|   |-- sqli_antes_conteo.txt
|   `-- sqli_despues_conteo.txt
`-- README.md
```

- El payload de antes y el de despues son identicos.
- La variante se probo o se declaro no probada.
- La funcionalidad legitima se verifico despues del parche.
- La conclusion distingue mitigado de no verificado.

5 Cómo se corrige

Criterio	Peso
Correcciones que eliminan la causa raíz, no el síntoma	3,0
Demostración antes y después con el mismo payload	2,5
Controles automatizados ejecutados e interpretados	2,0
Criterio de aceptación que previene la regresión	1,5
Sin regresiones funcionales en la aplicación	1,0
Total	**10,0**

- Cambiar el payload para que falle no demuestra nada.
- Un parche que rompe la aplicacion no es una mitigacion aceptable.

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.